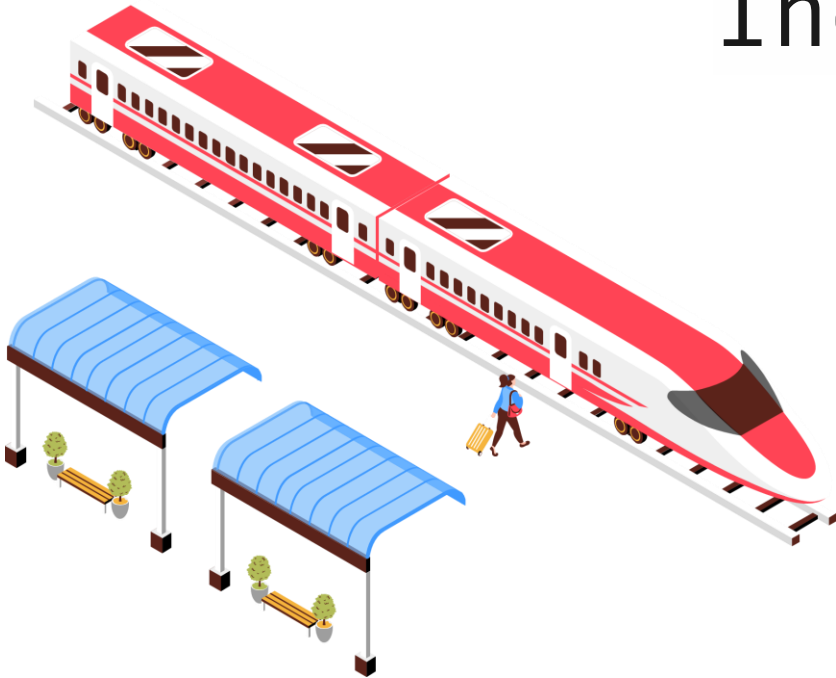


Cyber-security in Industrial Control Systems

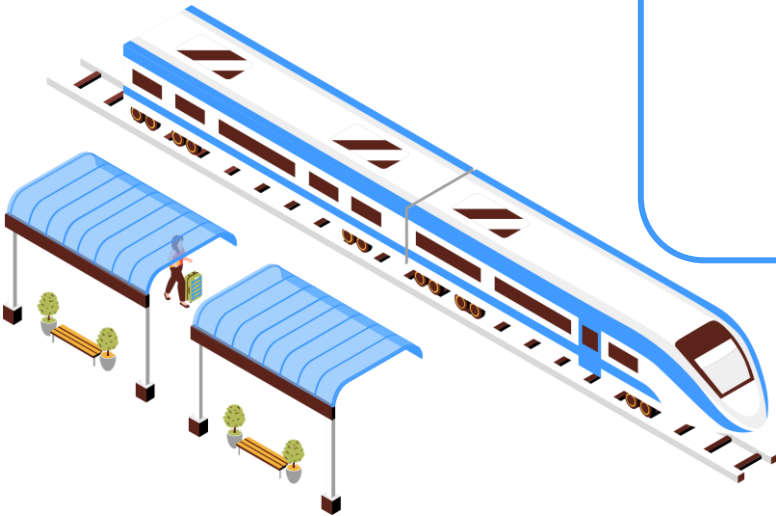


**Kawtar Zerhouni, Maîtresse de conférences
UTER MID@S - ECC**

We can collect traffic, logs, and events, but a single alert doesn't mean much. The real challenge is connecting small, scattered clues into a clear attack story.

That's what the cyber kill chain gives us: a simple framework to turn signals into a scenario.

Overview of the Cyber kill chain





What is the cyber kill chain ?

- The concept of the cyber kill chain was created by analysts at Lockheed Martin Corporation in 2011.
- It describes the stages of the process of compromising a victim.
- It is referred to as a chain because all stages rely on each other, and they need to be performed in succession.
- The idea is that if the chain gets broken somewhere in the process, the process gets halted.

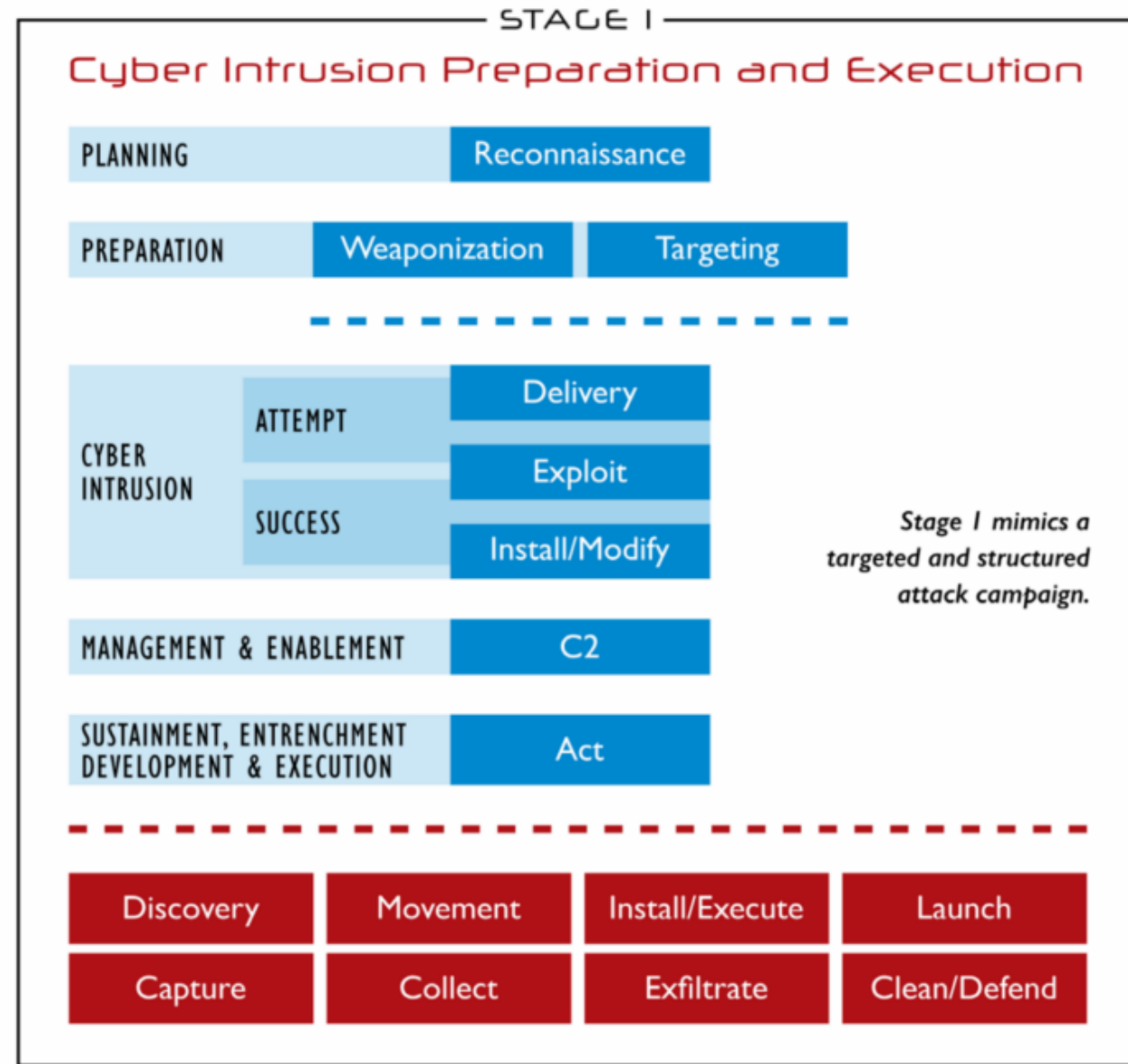
The Industrial Control System Cyber Kill Chain was published as a white paper by the SANS, to distinguish the two stages of an ICS attack.



Stage I

Reconnaissance:

- This initial stage involves gathering information about the target ICS environment.
- Attackers may seek to identify the types of systems in use, their configurations, network topology, and potential vulnerabilities.
- Reconnaissance can be conducted through various means, including passive scanning, open-source intelligence (OSINT), social engineering, and other information-gathering techniques.

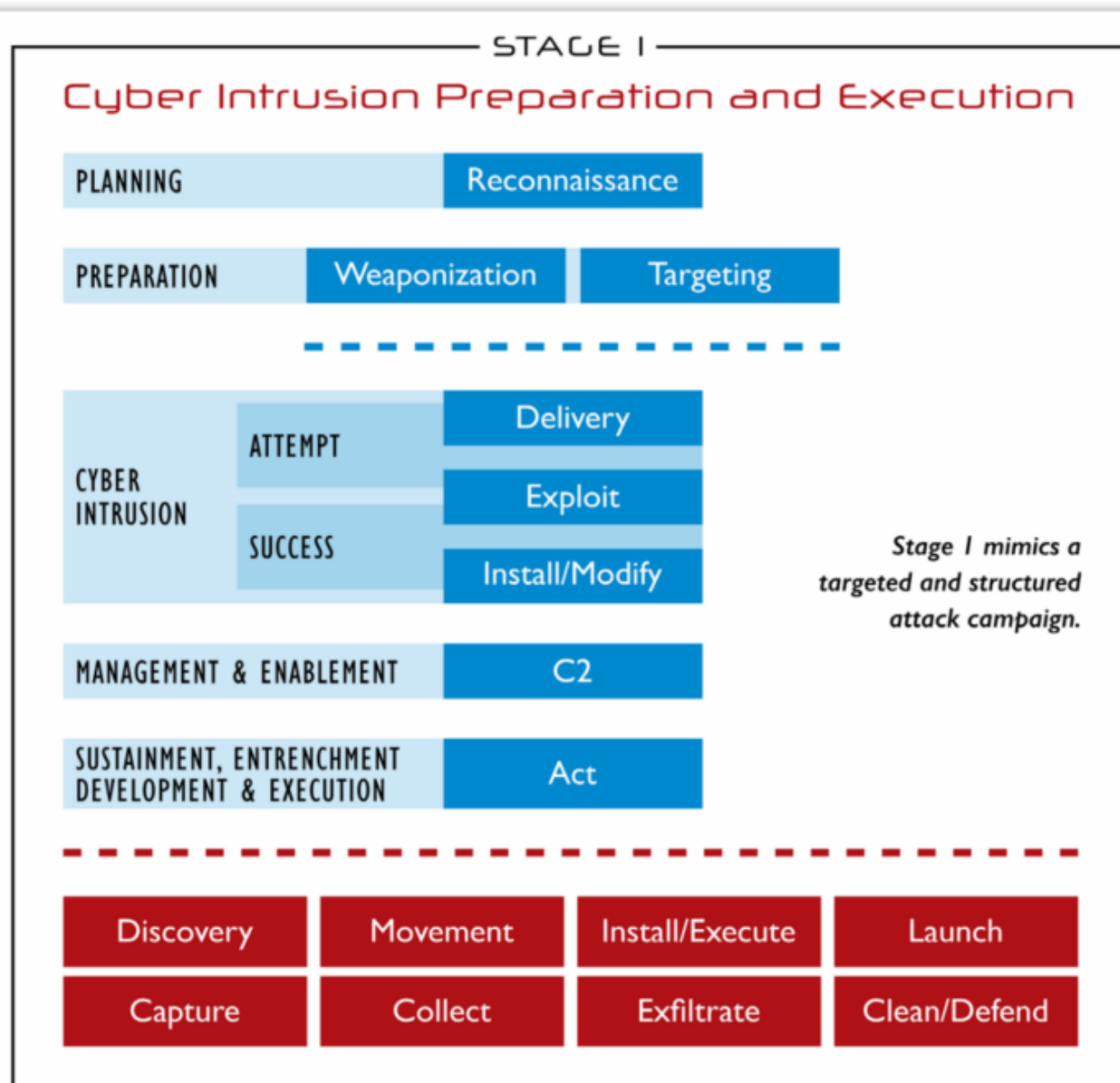




Stage I

Weaponization:

- In this stage, attackers develop or acquire the tools, malware, or other malicious payloads they will use to exploit **vulnerabilities identified** during **reconnaissance**.
- This may involve developing custom malware specifically designed to target ICS systems or obtaining existing malware from various sources.





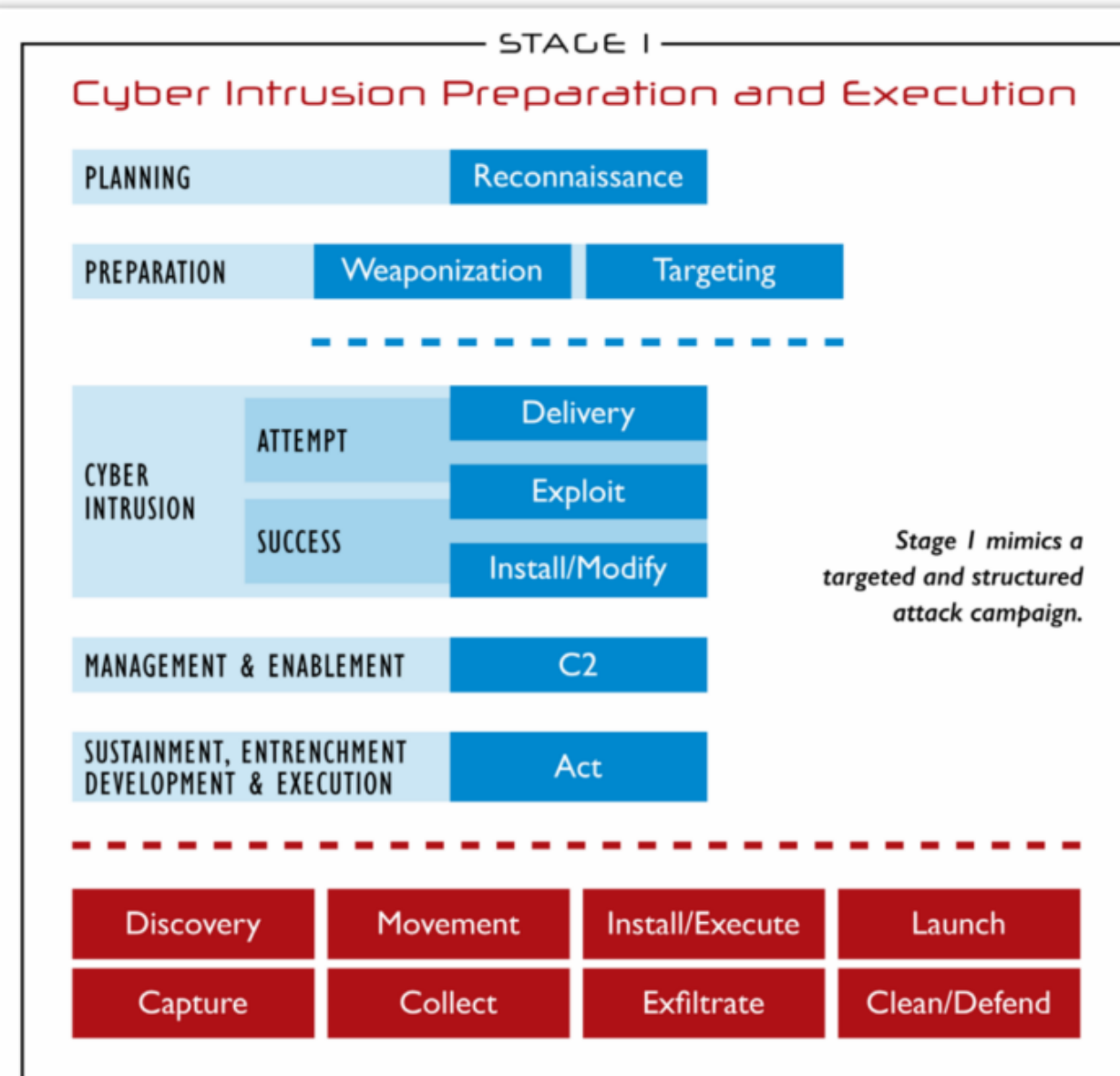
Stage I

Delivery:

- Delivery methods could include phishing emails, malicious websites, compromised USB devices, or exploiting vulnerabilities in network protocols.

Exploitation:

- Attackers use the delivered payload to exploit vulnerabilities within the target ICS environment.
- Taking advantage of software misconfigurations, or weak authentication mechanisms.





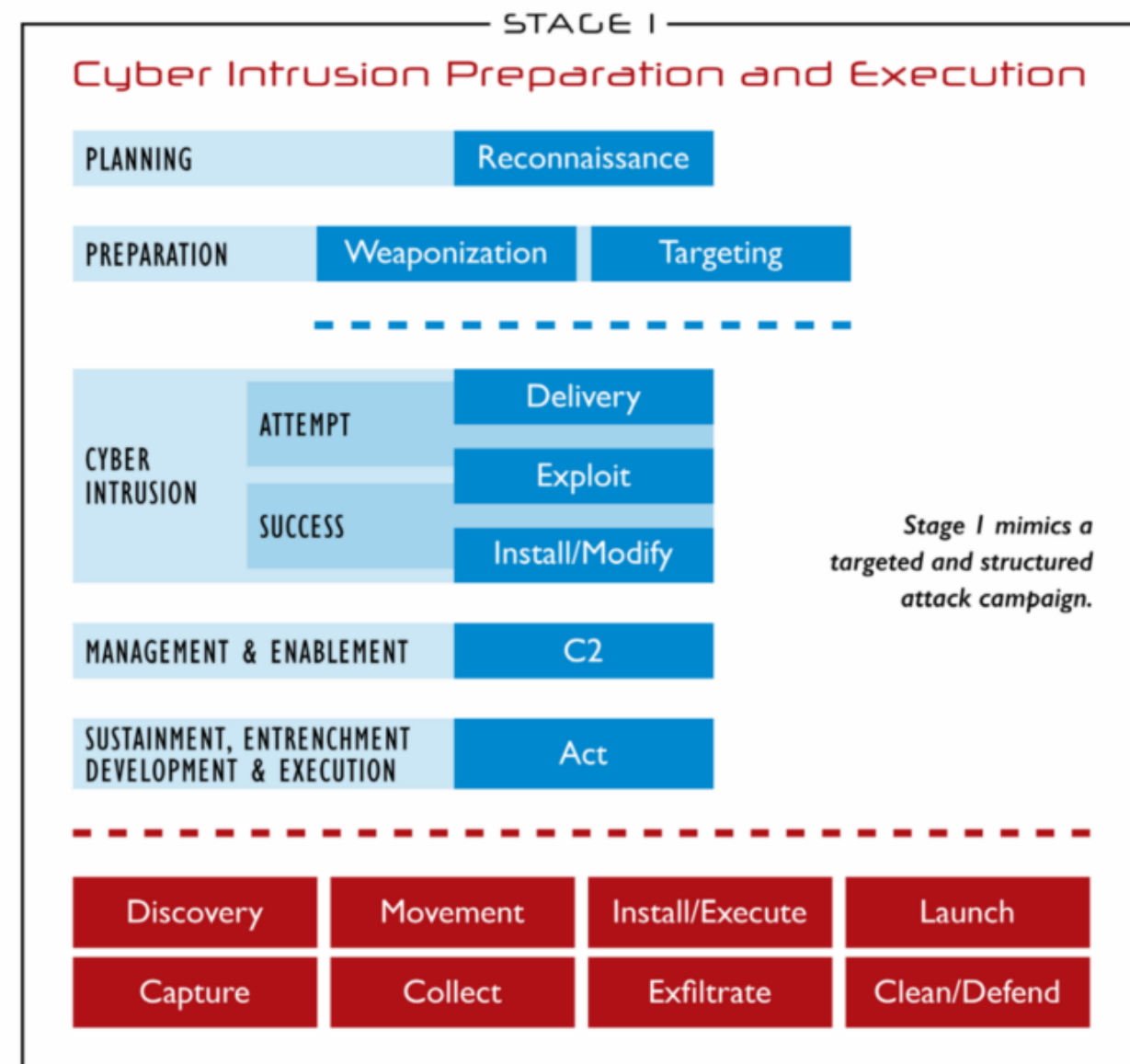
Stage I

Installation:

- After successfully exploiting vulnerabilities, attackers install their malicious code or establish **persistence** within the target systems.
- Allows them to **maintain** access to the compromised environment and continue their operations over an extended period.

Command and Control (C2):

- Attackers establish communication channels with the compromised systems to exert control over them remotely.
- This could involve using remote access tools, or other covert communication methods.

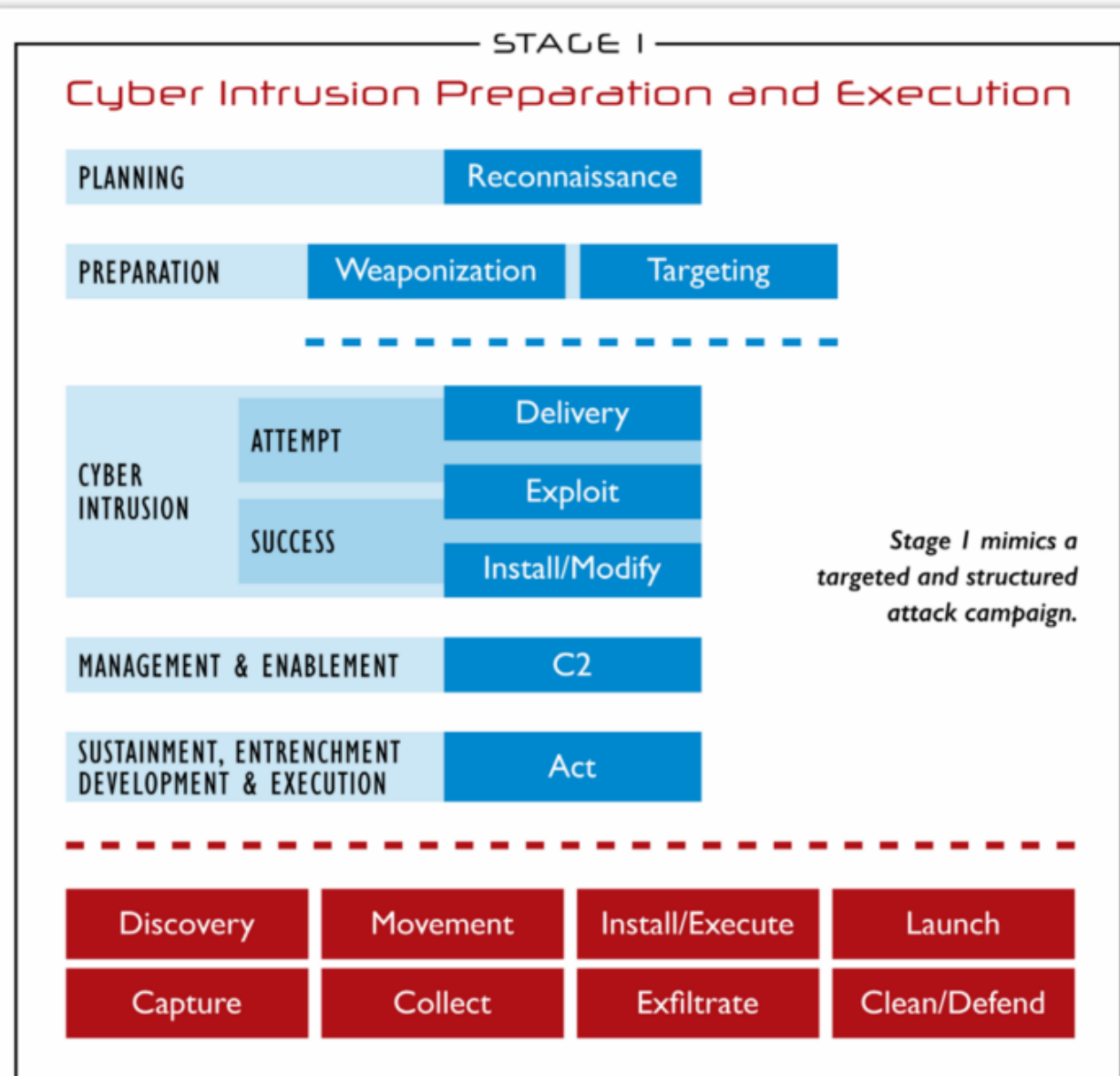




Stage I

Actions on Objectives:

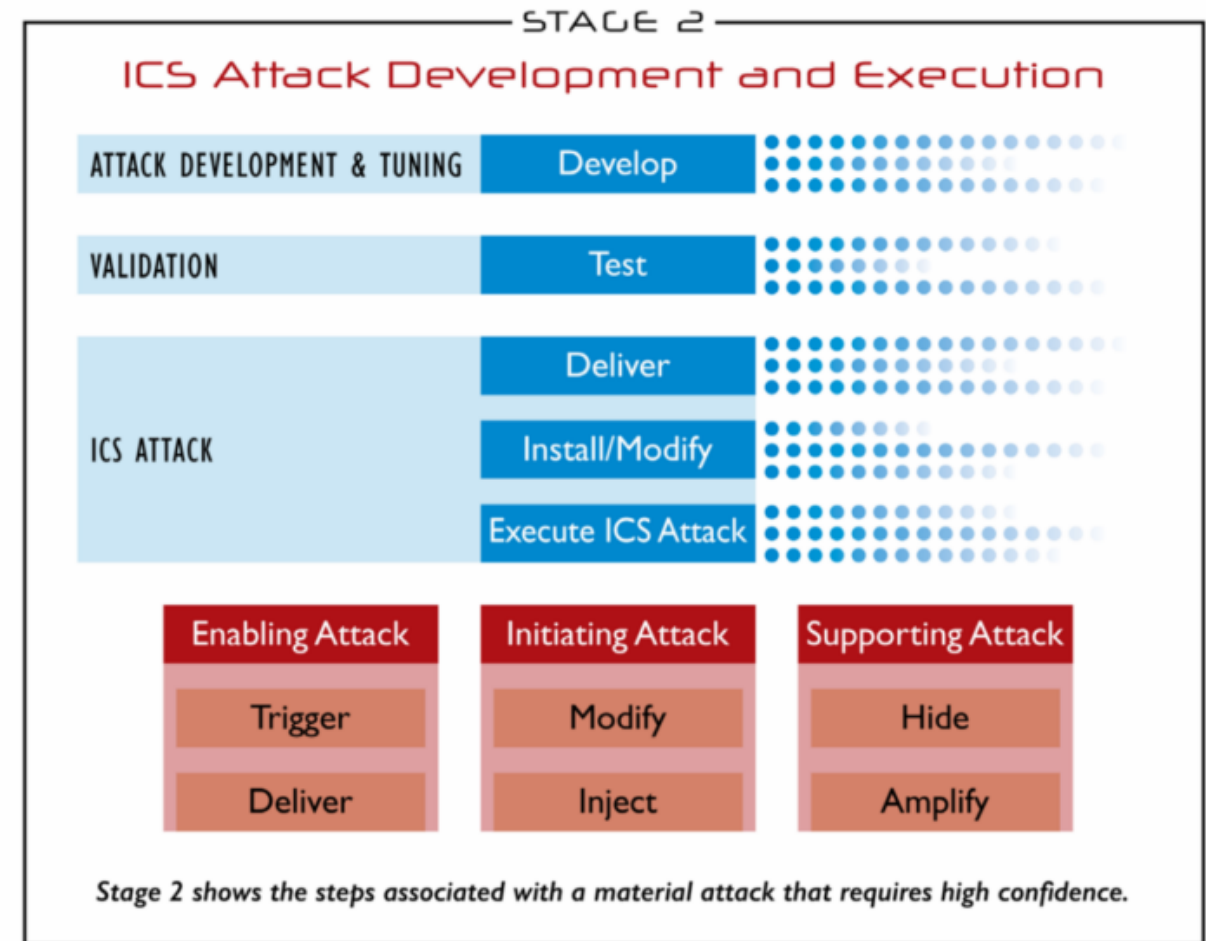
- Once they have established control over the compromised systems, attackers proceed to carry out their primary objectives.
- This could involve disrupting industrial processes, causing physical damage to critical infrastructure, stealing sensitive data, or achieving other malicious goals.





Stage II

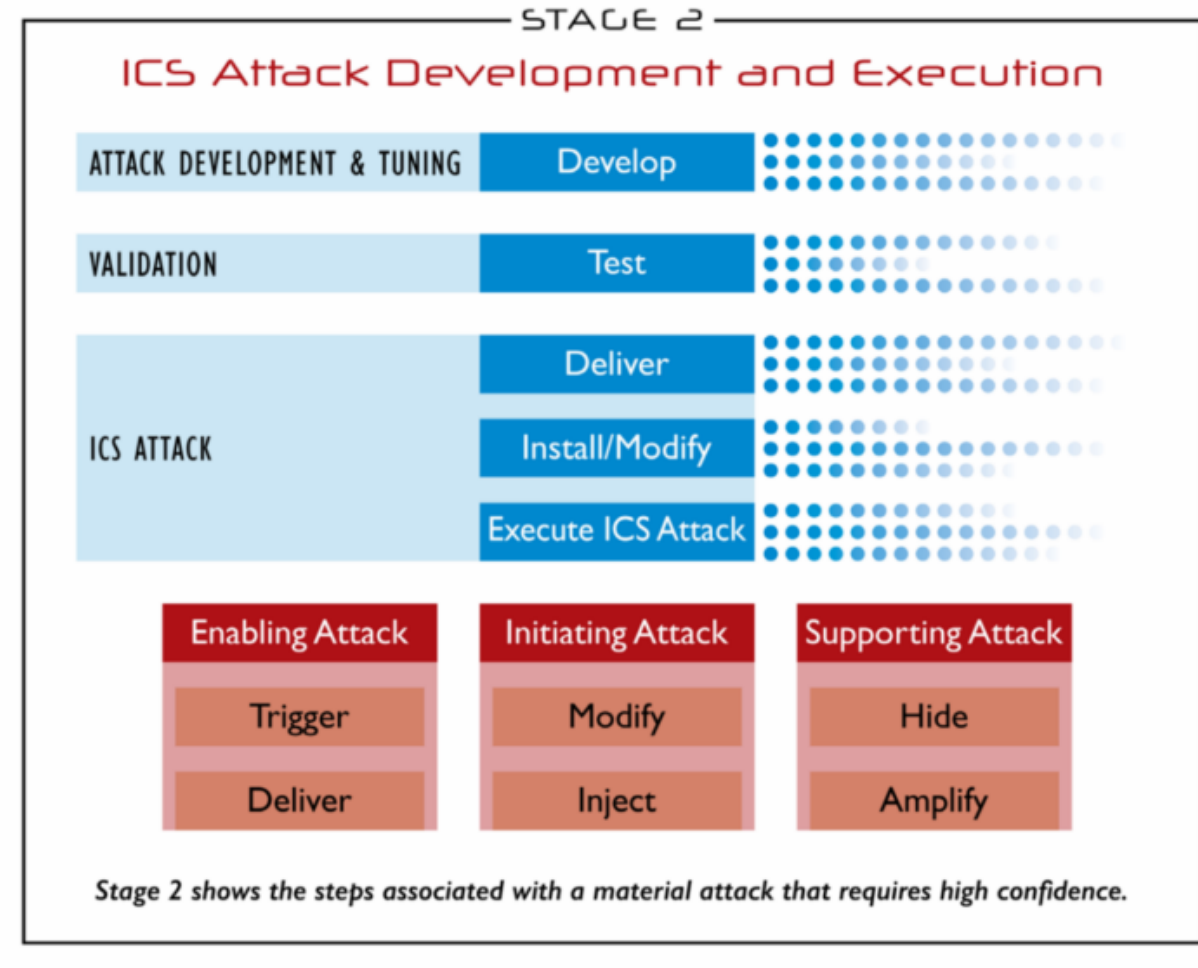
- In Stage 2 of the ICS Cyber Kill Chain, attackers move into the **Attack Development and Tuning phase**,
- Develop customized capabilities specifically tailored to exploit vulnerabilities in the target ICS environment for their desired impact.
- This development typically occurs using data obtained from reconnaissance efforts.





Stage II

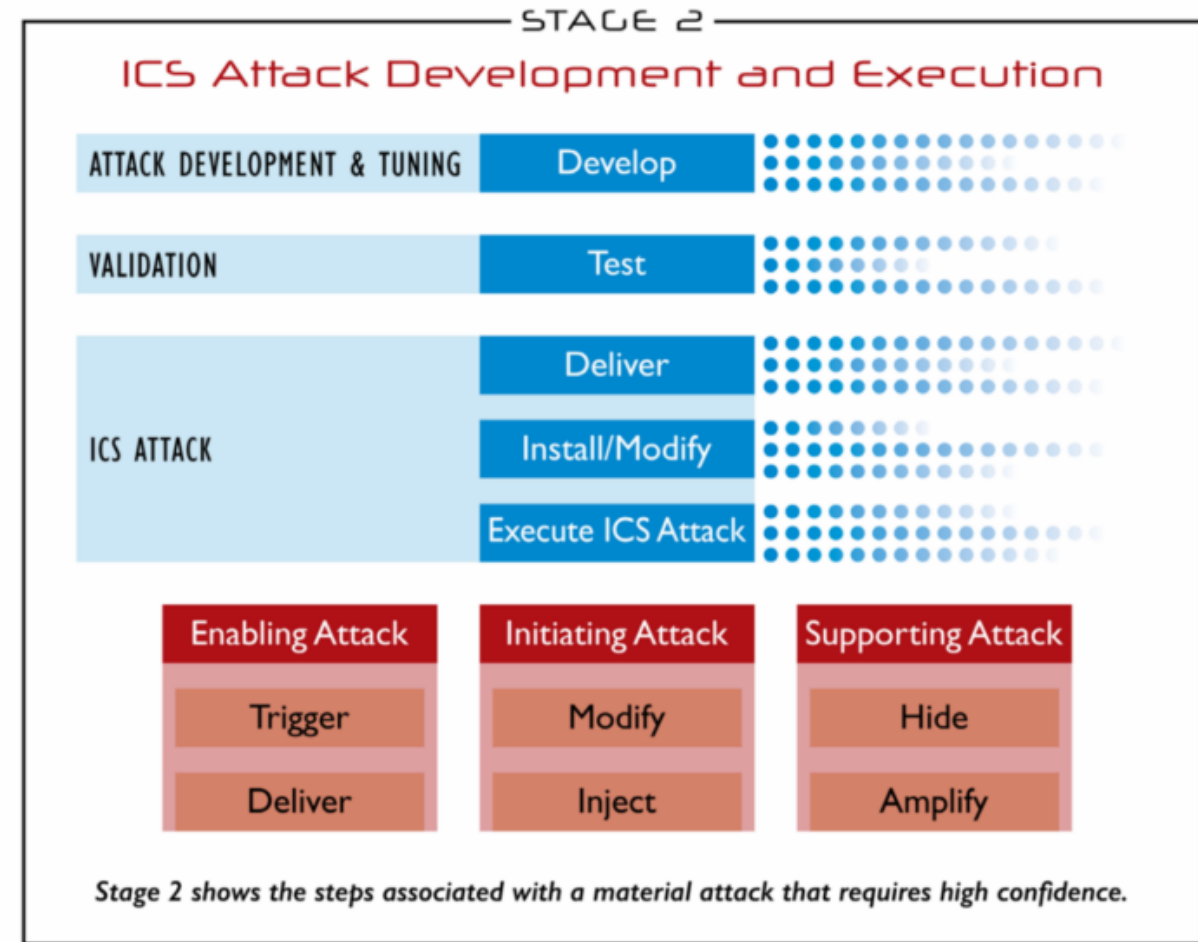
- **Validation**
- attackers test their developed capabilities to ensure they will have the desired impact on the target ICS environment.
- This phase involves testing the capabilities on similar or identically configured systems to confirm their effectiveness.





Stage II

- **ICS Attack phase,**
- the attacker executes the developed capability on the target ICS.
- This phase involves **delivering** the capability to the target environment, **installing it, or modifying** existing system functionality to facilitate the attack.



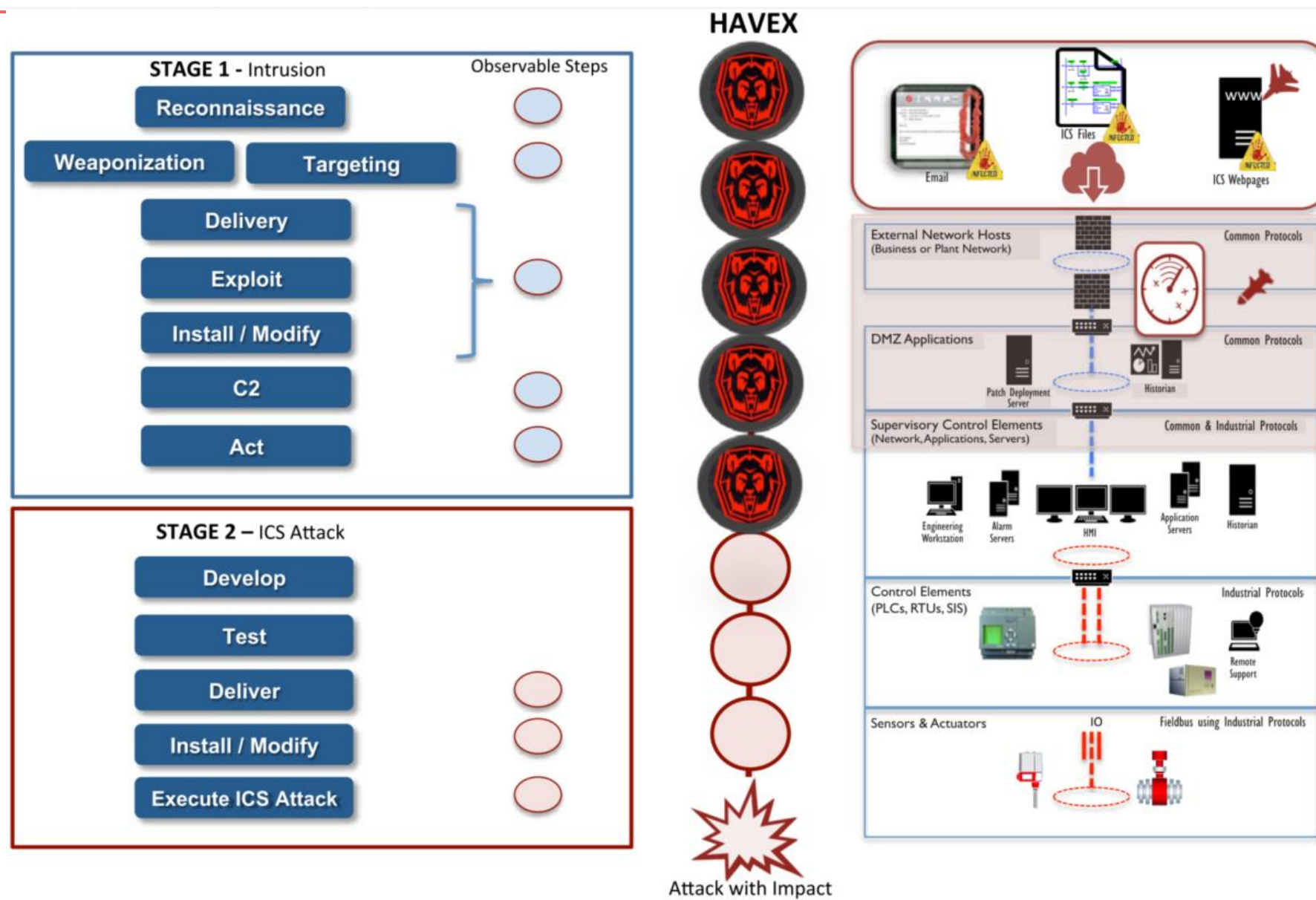


Example : Havex – the cyber espionage campaign

- The attack campaign was first **discovered** in 2014 by security researchers.
- It began with **targeted phishing emails** containing malicious attachments, such as Microsoft Office documents or PDF files, which exploited vulnerabilities to infect the victim's system. → **used for Reconnaissance**
- Once a system was compromised, the attackers deployed the **Havex malware**.
- This malware is a sophisticated Remote Access Trojan (RAT) designed specifically to target industrial control systems.
- It is capable of collecting system information, stealing credentials, and providing remote access to the compromised systems.



Example : Havex – the cyber espionage campaign



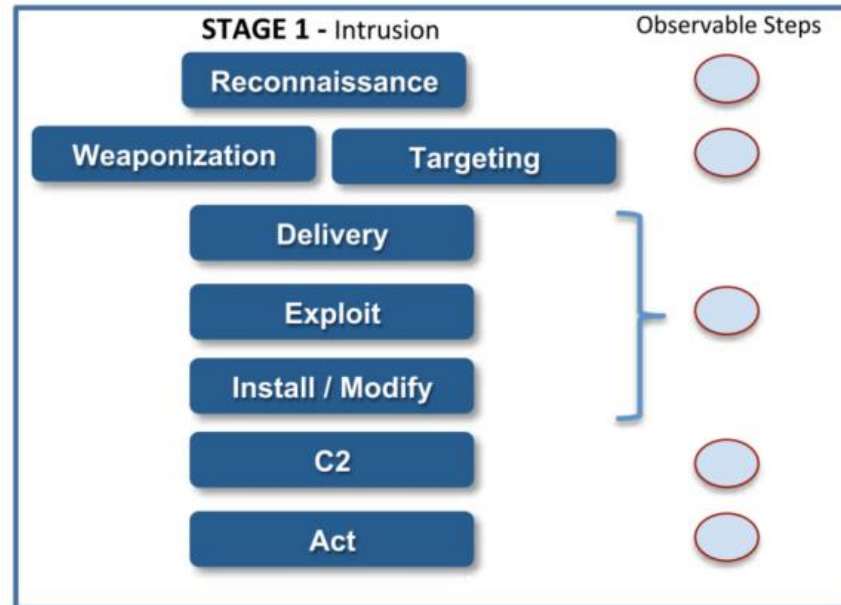


Example : Stuxnet – the cyber espionage campaign

- Stuxnet was first discovered in June 2010 by cybersecurity researchers.
- It initially spread via **infected USB drives**, exploiting vulnerabilities in Windows operating systems to infect computers.
- Stuxnet was specifically designed to target **Siemens Step7 software**, which is used to program and manage PLCs.
- Stuxnet employed **multiple zero-day vulnerabilities**, which are previously unknown software vulnerabilities, to infiltrate and compromise its target systems.
- Once inside the PLCs, Stuxnet **altered the code** of the ICS responsible for managing centrifuges used in Iran's uranium enrichment facilities.
- It manipulated the **speed of the centrifuges**, causing them to spin at speeds outside of their safe operating range, which ultimately damaged the centrifuges.



Example : Stuxnet – the cyber espionage campaign



STUXNET



Attack with Impact

